

Force brute RDP : detection dans le SIEM

Attaque (Hydra) -> Detection (Wazuh regle 100014) -> Investigation analyste
KHEN - Lab SOC | 24 juillet 2026 | MITRE ATT&CK T1110 (Brute Force)

Rouge = attaque	Bleu = detection / SIEM	Vert = outil / correctif	Gris = resultat
------------------------	--------------------------------	---------------------------------	------------------------

1. Objectif

Simuler une attaque par force brute sur le service RDP d'un serveur, la faire detecter par le SIEM Wazuh (regle personnelle 100014), puis l'investiguer et y reagir comme un analyste SOC. But pedagogique : valider une regle de detection de bout en bout et apprendre a lire une alerte dans le tableau de bord.

2. C'est quoi une attaque par force brute ?

Un attaquant essaie **enormement de mots de passe a la suite, tres vite**, en esperant tomber sur le bon et entrer dans un compte. Comme un voleur qui teste toutes les cle d'un trousseau sur une serrure. C'est l'un des tout premiers vecteurs d'intrusion dans la vraie vie (notamment via un RDP expose).

Signal SOC : Cote defense : chaque echec de connexion Windows genere l'evenement **4625**. Une **rafale** de 4625 depuis la meme source en peu de temps = la signature d'une force brute. C'est ce que notre regle detecte.

3. Elements du lab

Role	Machine	Adresse / Detail
Attaquant	VM Kali (VirtualBox)	[KALI] - outil : hydra
Cible	Windows Server 2022 (controleur de domaine)	[SERVEUR] - SRV-LAB.lab.local
Agent SIEM sur la cible	Agent Wazuh 002	collecte le journal Security (Event 4625)
SIEM (central)	Wazuh 4.12 (Docker dans WSL2)	Tableau de bord : https://localhost

4. Preparer la cible (activer RDP)

RDP = le service Bureau a distance de Windows, sur le port **3389**. Il doit ecouter pour etre attaquable. Sur le serveur (PowerShell administrateur) :

Windows Server 2022 - PowerShell admin

```
Set-ItemProperty -Path "HKLM:\System\CurrentControlSet\Control\Terminal Server" `
    -Name "fDenyTSConnections" -Value 0
Enable-NetFirewallRule -Group "@FirewallAPI.dll,-28752"
Get-NetTCPConnection -LocalPort 3389 -State Listen
```

Commande	Role
fDenyTSConnections = 0	autorise le Bureau a distance (0 = ne pas refuser)
Enable-NetFirewallRule -Group "@FirewallAPI.dll,-28752"	ouvre le pare-feu pour RDP (identifiant de groupe independant de la langue)
Get-NetTCPConnection -LocalPort 3389 -State Listen	verifie que RDP ecoute (une ligne = OK)

Bon reflexe : Verifier aussi la strategie de verrouillage avec `net accounts` (ligne « Seuil de verrouillage »). Ici : **Jamais** - aucun compte ne se bloque.

5. L'attaque (Hydra, depuis Kali)

On cible volontairement un **faux compte** (hacktest) : aucun compte reel ne risque d'etre bloque, et Windows note quand meme l'echec (4625) pour un nom inconnu.

5.1 Creer une petite liste de mots de passe

Kali

```
printf 'azerty\n123456\npassword\nadmin\nqwerty\nletmein\nsoleil\nmotdepasse\ntest123\nroot\n' > /tmp/p
```

5.2 Lancer la force brute sur RDP

Kali

```
hydra -l hacktest -P /tmp/pw.txt rdp://[SERVEUR] -t 4 -V
```

Option	Role
-l hacktest	le login (nom) a tester = hacktest. -l minuscule = UN seul login
-P /tmp/pw.txt	la LISTE de mots de passe (fichier). -P majuscule = liste
rdp://[SERVEUR]	le service (rdp) et l'adresse de la cible
-t 4	nombre d'essais en parallele
-V	mode verbeux : affiche chaque essai

A savoir : Pieges rencontres : (1) **-p minuscule** = UN seul mot de passe, **-P majuscule** = un FICHER liste (ne pas confondre). (2) Le module RDP d'hydra est « experimental » ; avec `-t 4` il peut afficher `freerdp: connection failed / « too many connection errors »` (RDP+NLA n'aime pas le parallele). Il genere quand meme les 4625 ; passer a `-t 1` le fiabilise.

Sortie : Resultat : hydra teste les 10 mots de passe, tous echouent (compte inexistant, c'est voulu). Chaque essai genere un evenement 4625 sur le serveur. Verifiable sur la cible : `Get-WinEvent -FilterHashtable @{LogName='Security'; Id=4625; StartTime=(Get-Date).AddMinutes(-3)} | Measure-Object.`

6. La chaine de detection Wazuh

Kali (hydra)

- > Serveur : chaque echec = Event 4625 dans le journal Security
- > Agent Wazuh 002 lit le journal Security et l'envoie au central
- > Regle native 60122 : 'Logon Failure' (matche Event 4625, niveau 5)
- > Regle 100014 : 5 fois 60122 sur le meme compte en 30 s -> ALARME (niveau 12)

La regle personnelle 100014 (sur le central)

```
<rule id="100014" level="12" frequency="5" timeframe="30">
  <if_matched_sid>60122</if_matched_sid>
  <same_field>win.eventdata.targetUserName</same_field>
  <description>Brute force detecte : 5 echecs en 30 s sur le meme compte</description>
  <mitre><id>T1110</id></mitre>
</rule>
```

frequency=5 / timeframe=30 = il faut 5 declenchements en 30 s. **same_field targetUserName** = les 5 echecs doivent viser **le meme compte**. Elle s'appuie sur la regle officielle 60122 (echec 4625).

7. Voir l'attaque dans le SIEM (cote analyste)

Dans le navigateur : <https://localhost> -> menu -> **Threat Hunting** -> onglet **Events** -> periode **Last 24 hours**. Dans la barre de recherche :

```
rule.id:100014
```

Resultat : les alertes de force brute s'affichent (niveau 12), et l'histogramme montre les **pics** des rafales. Deplier une ligne montre : source [KALI], compte vise hacktest, MITRE T1110, agent WindowsServer2022.

Piege SIEM : Piege d'analyste vecu : un filtre reste actif (rule.level: 15 to +∞) cachait l'alerte (niveau 12) et affichait « No results ». **Toujours verifier les filtres actifs** avant de conclure qu'une alerte n'existe pas.

Faux positifs : Bruit vecu : la regle native **92213** (niveau 15) criait « Executable dropped in malware folder » en masse - mais c'etaient des **faux positifs** (fichiers __PSScriptPolicyTest_*.ps1 crees normalement par PowerShell). Lecon : **un niveau eleve n'est pas une vraie menace** ; trier le vrai du faux est le coeur du metier.

8. Investigation : l'attaque a-t-elle reussi ?

Le reflexe qui fait l'analyste : voir des echecs ne suffit pas. LA question = **l'attaquant est-il entre ?** On cherche une **connexion reussie (Event 4624)** depuis la meme IP :

```
data.win.eventdata.ipAddress:[KALI] and data.win.system.eventID:4624
```

Resultat	Interpretation	Reaction
0 resultat (4624)	aucune connexion n'a abouti	tentative echouee - a surveiller
1+ resultat (4624)	quelqu'un a reussi a entrer	COMPROMISSION - incident, escalade

Verdict : Verdict de l'exercice : **0 connexion reussie, 43 echecs** depuis Kali sur hacktest. L'attaque a **echoue** - tentative, pas compromission. Reaction reelle : bloquer l'IP source au pare-feu, surveiller le compte vise, tracer.

9. Piege de production debogue : l'agent muet

Point majeur de l'exercice. L'agent 002 apparaissait « **Active** » (**connecte**) mais **n'envoyait aucun evenement** : le serveur notait bien les 4625, mais rien n'arrivait au SIEM.

- Cause : le journal Security de l'agent avait un **filtre local** (une longue liste d'exclusions EventID != . . .) qui, apres le redemarrage du serveur, s'est **coince** et a bloque tout le canal. L'agent de l'hote, sans ce filtre, fonctionnait.
- Diagnostic gagnant : comparer l'agent muet a un agent qui marche, et lire le journal de l'agent (ossec . Log) - il indiquait « Log file 'Security' is duplicated ».

- Correctif : retirer le bloc filtre local (sauvegarde faite), ne garder que la collecte propre sans filtre, puis redemarrer l'agent (Restart-Service WazuhSvc).

A retenir : Lecon SOC en or : un agent « **vert / connecte** » **peut ne plus rien envoyer** = un angle mort de detection. Surveiller la SANTE des agents (envoient-ils vraiment ?), pas seulement leur connectivite.

10. Aide-memoire (commandes)

But	Machine	Commande
Activer RDP	Serveur	Set-ItemProperty ... fDenyTSConnections -Value 0 ; Enable-NetFirewallRule -Group "@FirewallAPI.dll,-28752"
Verifier RDP	Serveur	Get-NetTCPConnection -LocalPort 3389 -State Listen
Verrouillage ?	Serveur	net accounts
Liste de mdp	Kali	printf 'azerty\n123456\n...' > /tmp/pw.txt
Force brute RDP	Kali	hydra -l hacktest -P /tmp/pw.txt rdp://[SERVEUR] -t 4 -V
Echecs sur la cible	Serveur	Get-WinEvent -FilterHashtable @{LogName='Security'; Id=4625; StartTime=(Get-Date).AddMinutes(-3)}
Voir l'alarme	Navigateur	https://localhost -> Threat Hunting -> Events -> rule.id:100014
Attaque reussie ?	Navigateur	data.win.eventdata.ipAddress:[KALI] and data.win.system.eventID:4624
Reveiller un agent	Serveur	Restart-Service WazuhSvc -Force

Resultat : regle 100014 validee (7 declenchements, niveau 12, T1110), attaque tracee jusqu'a la source, verdict d'analyste rendu (echec, pas de compromission), et un angle mort d'agent corrige. Cycle complet detecter -> voir -> investiguer -> reagir.